Universiti Tun Hussein Onn Malaysia

UNIVERSITI TUN HUSSEIN ONN MALAYSIA

FINAL EXAMINATION
SEMESTER I
SESSION 2023/2024

COURSE NAME	:	SOFTWARE SECURITY
COURSE CODE	:	BIS 20503
PROGRAMME CODE	:	BIS
EXAMINATION DATE	:	JANUARY / FEBRUARY 2024
DURATION	:	3 HOURS
INSTRUCTIONS	:	1. ANSWER ALL QUESTIONS 2. THIS FINAL EXAMINATION IS CONDUCTED VIA ☐ Open book ☒ Closed book 3. STUDENTS ARE **PROHIBITED** TO CONSULT THEIR OWN MATERIAL OR ANY EXTERNAL RESOURCES DURING THE EXAMINATION CONDUCTED VIA CLOSED BOOK

THIS QUESTION PAPER CONSISTS OF **SIX (6)** PAGES

TERBUKA

PART A

Instruction: Determine whether each of these statements is TRUE or FALSE.

Q1 Confidentiality ensures that information is consistently accessible and usable by authorized users when needed.

(1 mark)

Q2 Based on **Figure Q2.1**:

```
1  #include <stdio.h>
2  #include <string.h>
3
4  int main() {
5      char username[] = "admin";
6      char password[] = "password123";
7
8      char input_username[50];
9      char input_password[50];
```

Figure Q2.1

Code at line 6 is an example of a weak hard coding implementation.

(1 mark)

Q3 Role-Based Access Control (RBAC) assigns permissions based on a user's job function or role within an organization.

(1 mark)

Q4 Query size restriction is a technique used to defend against inference attacks by denying queries that can lead to a compromise.

(1 mark)

Q5 Compartmentalizing, also known as separation of privilege is one of the security principles integrated into the system design.

(1 mark)

Q6 Using Hypertext Transfer Protocol Secure (HTTPS) only is sufficient to protect sensitive data.

(1 mark)

Q7 It is not necessary to validate input to the system if the environment is considered safe.

(1 mark)

TERBUKA

Q8 One of Cross Site Scripting (XSS) prevention rules is to Hypertext Markup Language (HTML) encode before inserting untrusted data into HTML attribute values.

(1 mark)

Q9 Based on **Figure Q9.1**:

```
String data = request.getParameter( data );

if (osName.toLowerCase().startsWith( windows )) {
    String[] cmd = { cmd.exe , /c , data};
    Runtime.getRuntime().exec(cmd);
}
```

Figure Q9.1

Figure Q9.1 shows an example of code that lacks validation for command executing methods.

(1 mark)

Q10 Static testing involves reviewing code that is actively running and can be interacted with a web server or platform.

(1 mark)

Q11 A secure code review involves developer interviews, automated static analysis, manual review of the source code and a final report presentation of findings.

(1 mark)

Q12 Each layer of an operating system requires appropriate security measures to protect against attacks from lower layers.

(1 mark)

Q13 Patch and update all critical software are parts of the operating system security maintenance.

(1 mark)

Q14 Installing and configuring additional security tools, such as anti-virus software, host-based firewalls, Intrusion Detection / Prevention System (IDPS) and application white-listing, can enhance overall security.

(1 mark)

Q15 Encryption technology is only used to secure data in transit, and it does not play a role in securing data when stored.

(1 mark)

TERBUKA

Q16 Containers are significantly smaller than virtual machines because they only host the necessary parts of the operating system required to run an application.

(1 mark)

Q17 Virtualization allows for multiple operating systems to run on the same physical machine.

(1 mark)

Q18 Serverless applications are hosted and running on a server continuously.

(1 mark)

Q19 When a serverless application is invoked, it opens a container, runs its code to completion, and then self-destructs.

(1 mark)

Q20 It is recommended to always use the security features provided by the Cloud Service Provider (CSP) and monitor all networks and applications.

(1 mark)

TERBUKA

PART B

Instruction: Answer ALL questions.

Q21 Syabil, a dedicated hacker, wants to access confidential files on a corporate file server. He takes four steps to achieve his objective as follows.

```
1.0   Identify the corporate file server (AND)
2.0   Determine network topology and access points
      2.1   Sniff network traffic for active hosts and open ports (OR)
      2.2   Social engineering to gather network information (OR)
3.0   Bypass authentication measures
      3.1   Brute-force login credentials (OR)
      3.2   Exploit known vulnerabilities in authentication systems
4.0   Gain access to confidential files
      4.1   Exploit file system vulnerabilities (OR)
      4.2   Escalate privileges to gain access to restricted
            directories
```

Propose an attack tree diagram based on the above scenario.

(20 marks)

Q22 Alex works as a database administrator at Suasa Enterprise, a leading tech company. His main job is to keep the company's important data safe and make sure only the right people can get to it. One day, Alex gets an urgent message from Sarah, a senior developer. She tells him that the development team really needs to get into a super important database that has all the code for a new application they are working on. This database has secret details about the project, and they need to get in as soon as possible to meet a tight deadline.

Based on the given scenario, answer the following questions.

(a) Justify **THREE (3)** fundamental concepts of database security for Alex to handle effectively the request from Sarah.

(15 marks)

(b) Discuss a specific role and permissions that Alex needs to assign to Sarah based on Role Based Access Control (RBAC) model.

(5 marks)

Q23 Rizal is a software developer at a well-known tech company, was given the important job of building a new website for handling sensitive financial data. Understanding the seriousness of the task, Rizal knew that security had to be a top priority right from the start.

Based on the given scenario, answer the following questions.

(a) Discuss **FOUR (4)** phases of the Secure Development Lifecycle (SDL) that Rizal needs to integrate for developing the web application.

(12 marks)

TERBUKA

(b) Describe **FOUR (4)** potential abuse cases that could occur in the context of this web application handling sensitive financial information.

(8 marks)

Q24 Sara is a skilled software developer and manage a crucial project, building an online shopping cart for a well-known e-commerce site. This cart would process a high volume of transactions, including sensitive details like payment information. With the increasing security threats to e-commerce applications, Sara was planning to implement protections against Operating System (OS) command injection. She understood the risks and made sure the system would not be vulnerable to this type of attack.

Based on the given scenario, answer the following questions.

(a) Describe key characteristics and risks associated with command injection attacks on vulnerable applications.

(5 marks)

(b) Discuss **FIVE (5)** secure coding principle that Sara can apply to prevent against OS command injection.

(15 marks)

- END OF QUESTIONS -

TERBUKA